**COMPLAINTAI-BANK**

**DIGITAL BANKING AND AUTHENTICATION POLICY**

**Policy ID:** CPB-POL-006

**Version:** 1.0

**Policy Category:** Digital Banking and Authentication

# 1. Purpose

**Objectives**

This policy establishes the controls and procedures for accessing digital banking services, authenticating customers, protecting credentials and devices, authorizing digital transactions, and reporting suspicious access or digital-service incidents. It defines the responsibilities of customers and service teams for safe use of websites, mobile applications, digital wallets, online payment features, and other supported electronic channels.

The policy aims to reduce unauthorized access, protect personal and financial information, support reliable transaction authorization, and provide clear steps when authentication fails or suspicious activity is detected. A login event, authentication result, transaction instruction, and completed transaction are separate events and must not be treated as equivalent.

Controls and features may vary by service and device. Any specific authentication method, transaction limit, recovery method, or availability commitment must be verified against the applicable service requirements before it is presented as universal.

# 2. Scope

**Services and activities covered**

This policy covers online and mobile banking access, login credentials, multi-factor authentication, one-time passcodes, PINs and passwords, biometric authentication, trusted devices, device registration, digital-wallet access, session management, digital payment authorization, security notifications, password recovery, account lockouts, suspected phishing, device compromise, service downtime, and digital-banking complaints.

It also covers the collection and protection of authentication-related records, verification of identity during recovery, access restrictions, incident escalation, customer communication, and the recording of security-related requests. Product-specific transaction disputes and card payment issues should also be handled under the relevant card or fraud policy where applicable.

## 3. Definitions

**Key terms**

**Digital Banking:** A banking service accessed through a website, mobile application, or another approved electronic channel.

**Authentication:** A process used to verify a customer's identity or confirm access to an account, service, device, or transaction.

**Multi-Factor Authentication (MFA):** Authentication that requires more than one approved type of verification where supported by the service.

**One-Time Passcode (OTP):** A temporary verification code intended for a specific authentication or authorization event.

**Credential:** Information or a method used to access or authenticate to a service, including a password, PIN, passcode, security token, or approved biometric method.

**Trusted Device:** A device registered or recognized under an authorized process for access or additional verification.

**Digital Session:** A period during which a customer remains authenticated to a digital service.

**Phishing:** A deceptive message, website, or communication intended to obtain confidential information or induce an unsafe action.

**Account Lockout:** A restriction that prevents or limits login after defined security conditions are met.

**Security Incident:** An actual or suspected event that may compromise an account, credentials, device, personal information, or digital transaction.

**Digital Transaction:** A payment, transfer, account change, beneficiary update, or other instruction submitted through a digital service.

## 4. Access Eligibility and Secure Login

### 4.1 Authorized access

Customers should access digital services only through official applications, verified websites, or other channels formally provided for the relevant service. They should check the destination and avoid links received through unsolicited messages when signing in or entering financial information.

Access may depend on successful identity verification, account status, device compatibility, service availability, and required security checks. The availability of a login page does not guarantee that every account feature or transaction will be available.

### 4.2 Login information

Customers must protect their usernames, passwords, PINs, recovery details, and other credentials. Credentials should not be reused where a safer distinct password is available, written in a location accessible to others, or shared with individuals who claim they need them to provide support.

Customers should create passwords that are difficult to guess and follow any documented length or complexity requirements for the service. The service must not encourage customers to disclose existing passwords to support staff, and any password reset must use an authorized verification method.

### 4.3 Failed login and lockout

Repeated failed login attempts may trigger a temporary lockout, additional verification, or another protective control. A lockout is a security measure and does not, by itself, prove that an account has been compromised.

Customers who cannot sign in should use the official recovery process. If the customer suspects someone else has tried to access the account, the report should be treated as a potential security incident and should include the approximate time, notification details, and any unfamiliar activity that can safely be shared.

## 5. Multi-Factor Authentication and OTP Security

### 5.1 Authentication challenges

A service may request an OTP, in-app approval, biometric check, security token, or another verification step when a customer signs in, registers a device, changes sensitive details, or initiates a transaction. The applicable method depends on the service and the risk controls in place.

Customers should review the action described in an authentication prompt before approving it. They must not approve a login or transaction prompt that they did not initiate or do not understand. Repeated or unexpected approval requests should be reported through an authorized security channel.

### 5.2 OTP handling

An OTP is intended for the specific event for which it was issued and should be entered only in the authorized service flow that the customer initiated. Customers must not disclose OTPs to callers, message senders, or persons claiming to be support staff, and must not paste them into general complaint text.

If a customer shares an OTP or suspects that another person has obtained it, they should promptly secure the affected account, review recent activity, and report the circumstances. The service team should record the suspected exposure without requesting the actual OTP.

### 5.3 Biometric authentication

Where fingerprint, facial recognition, or another biometric method is supported, it may be used subject to device settings and the service's authentication design. Customers should protect access to the device itself and review which users or biometric profiles can unlock it.

If a device is shared, lost, or configured with another person's biometric access, the customer should reassess whether the device remains suitable for banking access and remove or reconfigure unauthorized access using the device's approved settings.

## 6. Device Registration and Device Security

### 6.1 Device registration

A service may require a device to be registered, verified, or recognized before permitting certain actions. Device registration may involve additional authentication, confirmation through a previously approved channel, or a review period where the service requires it.

Customers should register only devices they control and recognize. If a customer receives an unexpected device-registration alert, or discovers a device they do not recognize in the account's security settings, they should report it and request a review through the authorized process.

### 6.2 Lost, stolen or compromised devices

If a device used for digital banking is lost, stolen, infected with suspected malicious software, or accessed by an unauthorized person, the customer should use a safe alternative device or authorized support channel to secure the relevant account.

Protective steps may include revoking sessions, removing trusted-device status, changing credentials, disabling affected tokens, and checking recent transactions. The measures required depend on the service and exposure; changing a password alone may not address every compromised device or session.

### 6.3 Device and software maintenance

Customers should keep supported operating systems, banking applications, browsers, and device security features updated. They should avoid installing banking applications from unofficial sources and exercise caution with untrusted applications that request accessibility, screen-sharing, notification-reading, or remote-control permissions.

Where remote access or screen-sharing software was installed at the request of a suspicious caller, the customer should end the session, remove unauthorized access, and report the incident. The response should focus on the possible exposure and activity rather than assuming that installation alone proves funds were lost.

## 7. Session Management and Privacy in Public Environments

### 7.1 Session security

Customers should sign out when finished on a shared or public device and avoid storing credentials in browsers or devices they do not control. Screen locks and device access controls should be enabled where supported.

Digital services may automatically end an inactive session or require renewed authentication for sensitive actions. A session timeout is a protective control and should not be interpreted as confirmation that a pending transaction has been submitted or completed.

### 7.2 Shared networks and public devices

Customers should avoid performing sensitive banking tasks on untrusted devices and should be cautious when using public or shared networks. They should ensure that private account information is not visible to nearby people and avoid leaving statements, screenshots, or transaction information accessible after use.

If a customer believes a shared device or network exposed credentials or session information, they should use an authorized process to secure the account and review recent activity. Any known unusual transactions should be reported separately.

### 7.3 Notifications and privacy

Security notifications may reveal limited information about a login, device, transaction, or profile change. Customers should protect notification previews on lock screens and keep registered contact details current so that important messages can be received.

Customers should not forward security alerts containing personal or transaction information to unknown recipients. When asking support about an alert, they should share only the information needed to identify it and avoid disclosing authentication secrets.

## 8. Digital Transaction Authorization and Account Changes

### 8.1 Reviewing digital transactions

Before confirming a digital payment, transfer, beneficiary change, or sensitive account request, customers should review the displayed recipient, amount, currency, purpose, and other material details. Confirmation must be completed through the service's authorized authentication process.

An authentication event may demonstrate that a verification step occurred, but the final transaction status must be checked separately. A submitted instruction, pending payment, and completed transaction should be described according to the actual status recorded by the relevant system.

### 8.2 Sensitive profile changes

Changes to contact details, account access, recovery methods, beneficiaries, device registrations, or other sensitive settings may require stronger authentication or additional verification. Customers should review any confirmation notice received after such a change.

If a change appears that the customer did not make, the issue should be treated as potential unauthorized access. Relevant sessions and credentials should be reviewed, and the account should be protected through the authorized process.

### 8.3 Unrecognized or rejected actions

If a transaction or account change is rejected, pending, or unclear, the customer should review available transaction history or confirmation records before repeating the action. Repeated submission may create duplicate requests where the original status has not yet updated.

If the customer does not recognize an action, they should report it promptly with the time, type of action, amount where relevant, reference, and notification details. Suspected unauthorized transactions must also be handled under the applicable fraud policy.

## 9. Security Alerts and Suspicious Activity

### 9.1 Recognizing warning signs

Potential warning signs include login alerts the customer does not recognize, unfamiliar trusted devices, unexpected OTP messages, password-reset notices, new beneficiary notifications, repeated authentication requests, unusual account changes, or transactions the customer did not initiate.

An alert may be generated by a legitimate security process or may itself be part of a deceptive communication. Customers should avoid using embedded links in unexpected messages and should verify the situation through an independently accessed authorized channel.

### 9.2 Reporting suspicious activity

Customers should report the alert or activity promptly and provide the approximate date and time, notification channel, affected service, device information if known, and related transaction references. They should preserve suspicious messages where safe, but should not click untrusted links or download attachments for the purpose of gathering evidence.

The receiving team should record what the customer observed, distinguish reported facts from verified system records, and identify whether credentials, devices, account access, or transactions may be affected. The team should not state that fraud is confirmed before the authorized review supports that conclusion.

### 9.3 Immediate protection

Where unauthorized access appears ongoing or credentials may be compromised, the customer should be guided to the relevant urgent security process, which may include changing credentials from a safe device, revoking active sessions, removing an unrecognized device, or blocking an affected payment instrument.

The exact protection needed depends on the incident. The response should avoid giving the impression that a single step guarantees complete security when other credentials or services may also be exposed.

## 10. Service Interruptions and Technical Problems

**10.1 Unavailable service**

Digital banking may be temporarily unavailable due to maintenance, connectivity issues, technical faults, device compatibility, or other operational conditions. Customers should use official service notices or authorized support to confirm whether an incident is known.

A service interruption should not be used as the basis for assuming that a transaction failed or succeeded. The transaction status should be checked using the relevant history or support process before the customer submits the same instruction again.

**10.2 Login and transaction errors**

When reporting an error, the customer should provide the service or feature affected, approximate time, device or browser type where relevant, safe error wording, and any reference shown. They should not send passwords, OTPs, full card security details, or unnecessary personal information.

The responsible team should review service availability, authentication results, account status, and any recorded transaction or error reference. Customer-facing guidance should distinguish a confirmed outage from an individual account restriction or unresolved technical issue.

**10.3 Follow-up and restoration**

Where the issue requires technical investigation, the report should be recorded with its current status, available diagnostic information, and any next step communicated to the customer. The customer should be informed when there is a confirmed resolution or when additional action is required.

A service should not be described as restored based solely on an assumed fix or an internal escalation. Restoration should be confirmed through the applicable service status or tested function.

## 11. Password Recovery, Access Restoration and Account Lockouts

**11.1 Recovery request**

Password resets, forgotten-user-ID assistance, device changes, and account-unlock requests must use an authorized recovery process. The process may require identity verification and confirmation through a registered or otherwise approved channel.

Support staff and automated systems must not bypass required verification merely because the customer reports urgency. If a recovery method is no longer accessible, the customer should be directed to the authorized alternative procedure.

**11.2 Recovery safeguards**

Recovery details should be updated only after the required verification is complete. A request to change a phone number, email address, recovery destination, or trusted device should receive appropriate review because such changes may enable later access to the account.

If the customer did not initiate a recovery request or receives an unexpected reset notification, the event should be reported as potentially suspicious. It should not be dismissed solely because the customer can still sign in.

**11.3 Restoration confirmation**

An access-restoration request should be considered complete only after the relevant service confirms that the restriction has been removed or the recovery process has succeeded. Submission of identity documents or creation of a support ticket does not establish that access has been restored.

Where access remains restricted, communications should identify any outstanding verification or review step that can be disclosed. The customer should not be promised a specific restoration time unless supported by confirmed service information.

## 12. Customer Responsibilities

**Customer obligations**

Customers are expected to:

1. Use official digital banking channels and verify website or application authenticity before entering credentials.
2. Keep passwords, PINs, OTPs, and recovery information confidential.
3. Review transaction details and account-change prompts before authorizing them.
4. Approve only authentication requests that they initiated and understand.
5. Secure devices with appropriate access controls and maintain supported software updates.
6. Report lost devices, unexpected logins, unfamiliar device registrations, and suspicious transactions promptly.
7. Avoid using untrusted devices or granting unnecessary remote access to banking devices.
8. Keep registered contact and recovery information current where required.
9. Retain relevant notification and case references without exposing authentication secrets.
10. Follow authorized recovery and security procedures and respond to reasonable verification requests.

## 13. Information Protection, Records and Monitoring

### 13.1 Handling security information

Customer identity data, device identifiers, authentication events, security alerts, and transaction records should be used only for authorized authentication, fraud prevention, support, investigation, and service purposes. Access should be limited according to role and operational need.

Authentication secrets such as passwords, PINs, CVVs, and one-time passcodes must not be stored in ordinary complaint notes or customer-support logs. Any diagnostic collection should be limited to the information required for the particular issue.

### 13.2 Security records and audit trail

Material authentication events, account changes, reported incidents, protective actions, customer communications, and restoration decisions should be recorded in accordance with applicable requirements. Records should distinguish customer-reported observations from system-verified events.

Records should be protected from unauthorized access, alteration, disclosure, and loss. Retention and disposal should follow applicable legal, regulatory, contractual, and organizational requirements.

### 13.3 Monitoring and alert handling

Where a service uses automated monitoring to identify unusual logins or transactions, an alert should be treated as a signal for the appropriate review rather than automatic proof of misconduct. Any restriction or further verification should follow the authorized security process.

Information about internal detection methods, risk signals, or security controls should not be disclosed beyond what is permitted. Customer explanations should remain useful without exposing details that could undermine protective measures.

## 14. Complaint Handling, Exceptions and Policy Review

### 14.1 Complaints covered

Customers may complain about login failure, account lockout, OTP delivery, device registration, biometric access, password recovery, unexpected alerts, digital transaction errors, unavailable services, unauthorized profile changes, or suspected account compromise.

A complaint involving suspected unauthorized transactions or fraud should also be handled under the relevant fraud and dispute policy. Registering a general service complaint must not delay urgent steps needed to protect credentials or payment instruments.

### 14.2 Complaint records and communication

After successful registration, a unique complaint reference should be provided. The record should identify the affected service, issue description, approximate time, relevant error or transaction reference, actions already taken, supporting material, current status, and required follow-up.

Customer communications should separate confirmed facts from suspected causes and avoid promises that credentials have been secured, transactions reversed, or access restored unless those results are confirmed by the appropriate system or team.

### 14.3 Exceptions and interpretation

Authentication methods, login controls, device-registration rules, session timeouts, recovery procedures, and availability commitments may vary by service. If the available documents do not establish a particular method, timeline, or security outcome, it must not be invented or presented as confirmed.

Where additional verification or a review is required, the customer should be directed to the authorized service channel. Security-sensitive details should be limited to information permitted for disclosure.

### 14.4 ComPlaintAI-Bank workflow integrity and review

Within ComPlaintAI-Bank, digital-banking complaints may be categorized and saved to the project database, then assigned to an internal queue according to configured rules. A system may confirm that a complaint was registered only after the database save succeeds.

The project must not claim that a real account was locked, a password was changed, a device removed, or an external security team contacted unless an authorized connected system confirms the action. This policy should be reviewed when digital services, authentication methods, security procedures, or applicable requirements change.

Related policies include Account Management and Banking Services Policy; Debit and Credit Card Services Policy; Fraud, Unauthorized Transactions and Disputes Policy; Fund Transfers, Remittances and Refunds Policy; Banking Fees, Charges and Interest Policy; Digital Banking and Authentication Policy; Customer Complaint Registration and Resolution Policy; and Complaint Priority, Department Routing and Data Privacy Policy.

**End of Policy**